

History Search Alerts Output Spider AJAX Spider Active Scan

Alerts (7)

- Content Security Policy (CSP) Header Not Set (Systemic)
- Cross-Domain Misconfiguration (Systemic)
- Server Leaks Version Information via "Server" HTTP Response
- Strict-Transport-Security Header Not Set (Systemic)
- Timestamp Disclosure - Unix (Systemic)
- Modern Web Application (Systemic)
- Re-examine Cache-control Directives (Systemic)

Cross-Domain Misconfiguration

URL: <https://demo.owasp-juice.shop/>

Risk: Medium

Confidence: Medium

Parameter:

Attack:

Evidence: Access-Control-Allow-Origin: *

CWE ID: 264

WASC ID: 14

Source: Passive (10098 - Cross-Domain Misconfiguration)

Input Vector:

Description:

Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.

Other Info:

The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other

History Search Alerts Output Spider AJAX Spider Active Scan

Alerts (7)

- Content Security Policy (CSP) Header Not Set (Systemic)
- Cross-Domain Misconfiguration (Systemic)
- Server Leaks Version Information via "Server" HTTP Response
- Strict-Transport-Security Header Not Set (Systemic)
- Timestamp Disclosure - Unix (Systemic)
- Modern Web Application (Systemic)
- Re-examine Cache-control Directives (Systemic)

Server Leaks Version Information via "Server" HTTP Response Header Field

URL: <https://demo.owasp-juice.shop/ftp/package-lock.json.bak>

Risk: Low

Confidence: High

Parameter:

Attack:

Evidence: Apache/2.4.68 (Unix)

CWE ID: 497

WASC ID: 13

Source: Passive (10036 - HTTP Server Response Header)

Alert Reference: 10036-2

Input Vector:

Description:

The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.

Other Info:

Solution:

History Search Alerts Output Spider AJAX Spider Active Scan

Alerts (7)

- Content Security Policy (CSP) Header Not Set (Systemic)
- Cross-Domain Misconfiguration (Systemic)
- Server Leaks Version Information via "Server" HTTP Response
- Strict-Transport-Security Header Not Set (Systemic)
- Timestamp Disclosure - Unix (Systemic)
- Modern Web Application (Systemic)
- Re-examine Cache-control Directives (Systemic)

Other Info:

domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.

Solution:

Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

Reference:

<https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy>

Alert Tags:

Key	Value
OWASP_2021_A01	https://owasp.org/Top10/A01_2021-Broken_Access_Control/
POLICY_GA_STD	
POLICY_PENTEST	
SYSTEMIC	https://www.zaproxy.org/docs/desktop/addons/common-library/alerttags/#sy...
OWASP_2025_A01	https://owasp.org/Top10/2025/A01_2025-Broken_Access_Control/

The screenshot shows the Burp Suite interface. On the left, the 'Alerts' tab is active, displaying a list of 7 alerts. The alert 'Modern Web Application (Systemic)' is selected and highlighted in blue. On the right, the details for this alert are shown. The URL is 'https://demo.owasp-juice.shop/'. The risk is 'Informational'. The confidence is 'Medium'. The parameter is empty. The attack payload is a JavaScript snippet that sets a cookie and displays a popup. The evidence shows the popup content, which is a message about fruit cookies and a link to a YouTube video. The CWE ID is 10109 (Modern Web Application). The WASC ID is empty. The source is 'Passive (10109 - Modern Web Application)'. The input vector is empty. The description is empty.

Alerts (7)	Modern Web Application (Systemic)
Content Security Policy (CSP) Header Not Set (Systemic)	URL: https://demo.owasp-juice.shop/
Cross-Domain Misconfiguration (Systemic)	Risk: Informational
Server Leaks Version Information via "Server" HTTP Response	Confidence: Medium
Strict-Transport-Security Header Not Set (Systemic)	Parameter:
Timestamp Disclosure - Unix (Systemic)	Attack:
Modern Web Application (Systemic)	<pre><script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But m e wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } }); </script></pre>
Re-examine Cache-control Directives (Systemic)	Evidence:
	CWE ID:
	WASC ID:
	Source: Passive (10109 - Modern Web Application)
	Input Vector:
	Description:

